

EXPERIMENT 1: THREAT MODELING USING THE MICROSOFT THREAT MODELING TOOL

1. Aim

To create a threat model for a sample scenario using the Microsoft Threat Modeling Tool, draw its data flow diagram (DFD), generate threats using the STRIDE methodology and record suitable mitigations.

2. Introduction

Threat modeling is a structured way of finding security problems in a system at the design stage, before code is written. The Microsoft Threat Modeling Tool lets the user draw a data flow diagram of the system and then automatically suggests threats for each element using the STRIDE categories: Spoofing, Tampering, Repudiation, Information disclosure, Denial of service and Elevation of privilege.

3. Requirements

- Windows 10 or later computer
- Microsoft Threat Modeling Tool (free download from the Microsoft website)
- A scenario to model (a sample scenario is used here and can be replaced by the scenario given by the faculty)

4. Sample Scenario

An online banking web application. A customer logs in from a browser. The web application checks the credentials and reads or updates account details stored in a database. The web application and database are inside the bank's network, which forms a trust boundary separate from the internet.

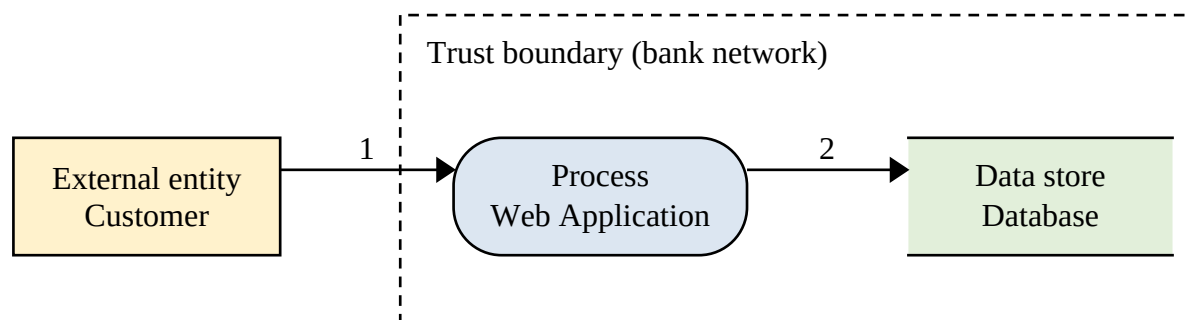
5. Procedure

- Install and open the Microsoft Threat Modeling Tool and click **Create A Model**.
- Select a template (for example the Azure Threat Model Template or the SDL TM Knowledge Base) and click Create.
- In the Design view, drag the stencils from the right-hand panel: External Entity (Customer), Process (Web Application), Data Store (Database), Data Flow arrows and a Trust Boundary box.
- Name each element and set its properties, such as whether authentication is used and whether data is encrypted.
- Switch to the **Analysis view**. The tool lists the generated threats grouped by STRIDE category.

- For each threat, set the state (Not Started, Needs Investigation, Not Applicable or Mitigated), set a priority and write the mitigation.
- Use **Reports > Create Full Report** to save the threat report as an HTML file.

6. Output

Figure 1: Data flow diagram of the sample scenario (illustrative)

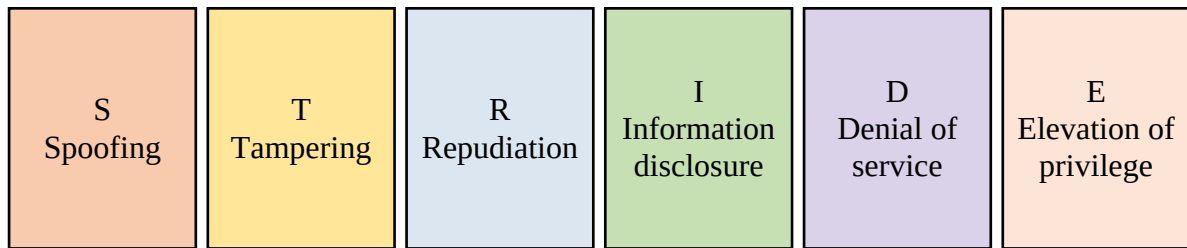


1 = Login request / response (HTTPS)

2 = Account query / update (SQL)

Figure 2: Threat list generated in the Analysis view (illustrative)

No.	Threat	STRIDE	Element	Suggested mitigation
1	Attacker pretends to be a valid customer	Spoofing	Customer to Web App	Strong password policy and multi-factor authentication
2	Request data modified in transit	Tampering	Flow 1	Use HTTPS (TLS) and input validation
3	User denies performing a transaction	Repudiation	Web App	Secure audit logs with time stamps
4	Account data exposed from database	Information disclosure	Database	Encrypt data at rest and restrict database access
5	Flood of requests makes site unavailable	Denial of service	Web App	Rate limiting and load balancing
6	Normal user gains admin rights	Elevation of privilege	Web App	Role-based access control and least privilege

Figure 3: STRIDE categories used by the tool

Each STRIDE category violates one security property

Note: The figures show the expected structure of the output. Exact names, values and screens may differ in your own environment and software version.

7. Result

A threat model was created for the sample online banking scenario. Its data flow diagram was drawn, threats were generated using STRIDE and mitigations were recorded in the threat report.